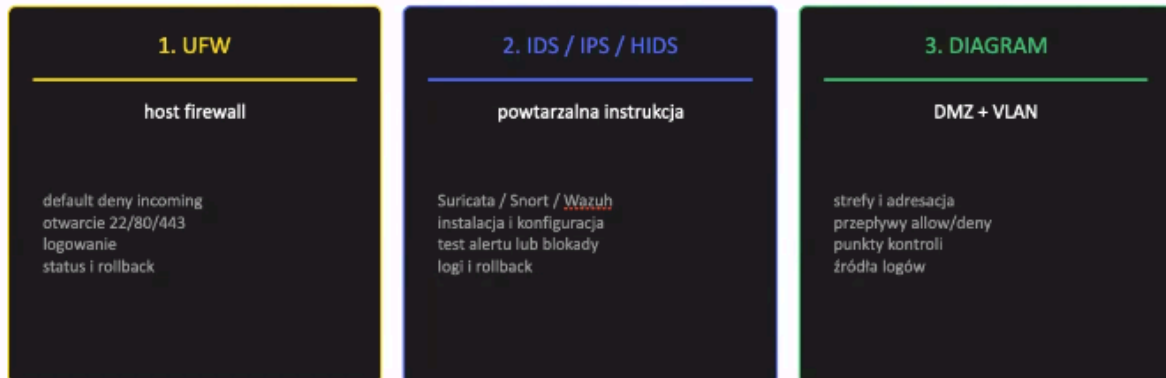


Laboratorium łączy egzekwowanie, detekcję i projektowanie

Trzy zadania — jeden model bezpiecznej sieci



1. Konfiguracja host firewall UFW wg. reguł z zadań w LMS
2. Przygotowanie powtarzalnej instrukcji dla instalacji oraz podstawowej konfiguracji (wraz z zastosowaniem przykładowych reguł) dla narzędzi IDS lub IPS lub HIDS. Wykorzystanie jednego z narzędzi: Suricata, Snort, Wazuh. Przeprowadzenie i dokumentacja pełnej instalacji oraz konfiguracji jednej z platformy, tak aby po potencjalnej "wymianie" dokumentacji inna osoba mogła przeprowadzić instalację narzędzia. W załączniku przykładowy schemat instrukcji README.md.
3. Przygotowanie przykładowego diagramu architektury bezpieczeństwa dla sieci zdefiniowanego przez siebie organu/organizacji/przedsiębiorstwa. Skupienie się na odpowiednim wykorzystaniu (lub nie) elementów kontroli bezpieczeństwa przedstawionych na zajęciach w odpowiednich miejscach oraz ich użyteczności. Celem ćwiczenia jest całościowe spojrzenie na system.

1. Konfiguracja UFW na hoście Ubuntu:

```
joanna@joanna-VirtualBox:~$ ^[[200~# 1. Reset i domyślna polityka (blokuj wchodzący, zezwalaj na wychodzący)
bash: błąd składni przy nieoczekiwanym znaczniku `('
joanna@joanna-VirtualBox:~$ sudo ufw reset
[sudo] hasło użytkownika joanna:
Niestety, proszę spróbować ponownie.
[sudo] hasło użytkownika joanna:
Resetowanie wszystkich zasad do domyślnie zainstalowanych. Kontynuować
operację (t|n)? t
Tworzenie kopii zapasowej 'user.rules' jako '/etc/ufw/user.rules.20260826_212053'
Tworzenie kopii zapasowej 'before.rules' jako '/etc/ufw/before.rules.20260826_212053'
Tworzenie kopii zapasowej 'after.rules' jako '/etc/ufw/after.rules.20260826_212053'
Tworzenie kopii zapasowej 'user6.rules' jako '/etc/ufw/user6.rules.20260826_212053'
Tworzenie kopii zapasowej 'before6.rules' jako '/etc/ufw/before6.rules.20260826_212053'
Tworzenie kopii zapasowej 'after6.rules' jako '/etc/ufw/after6.rules.20260826_212053'

joanna@joanna-VirtualBox:~$ sudo ufw default deny incoming
Domyślne zasady incoming zmieniono na 'deny'
(zaktualizuj odpowiednio swoje reguły)
joanna@joanna-VirtualBox:~$ sudo ufw default allow outgoing
Domyślne zasady outgoing zmieniono na 'allow'
(zaktualizuj odpowiednio swoje reguły)
joanna@joanna-VirtualBox:~$ sudo ufw allow 22/tcp
Zaktualizowano reguły
Zaktualizowano reguły (v6)
joanna@joanna-VirtualBox:~$ sudo ufw allow 80/tcp
Zaktualizowano reguły
Zaktualizowano reguły (v6)
joanna@joanna-VirtualBox:~$ sudo ufw allow 443/tcp
Zaktualizowano reguły
Zaktualizowano reguły (v6)
joanna@joanna-VirtualBox:~$ sudo ufw logging on
Logowanie włączone
joanna@joanna-VirtualBox:~$ sudo ufw enable
Zapora jest aktywowana i włączana podczas startu systemu
joanna@joanna-VirtualBox:~$ sudo ufw status numbered
Stan: aktywny

      Do                Działanie      Z
      --                -
[ 1] 22/tcp             ALLOW IN   Anywhere
[ 2] 80/tcp             ALLOW IN   Anywhere
[ 3] 443/tcp            ALLOW IN   Anywhere
[ 4] 22/tcp (v6)        ALLOW IN   Anywhere (v6)
[ 5] 80/tcp (v6)        ALLOW IN   Anywhere (v6)
[ 6] 443/tcp (v6)       ALLOW IN   Anywhere (v6)
```

2. Dokumentacja: Plik INSTRUKCJA.md znajduje się w katalogu domowym (/home/joanna/INSTRUKCJA.md).

```
cat << 'EOF' > INSTRUKCJA.md
```

```
# Instrukcja wdrożenia: Suricata (IDS)
```

```
## Wybrana ścieżka
```

Suricata jako pasywny NIDS (Network Intrusion Detection System) na interfejsie `enp0s3`.

```
## Cel i rola narzędzia
```

Analiza ruchu sieciowego w tle i ostrzeganie o podejrzanych pakietach bez blokowania przepływu danych.

```
## Architektura labu
```

```
* Host: Ubuntu (VirtualBox)
```

```
* Interfejs: `enp0s3`
```

```
* Rola: Pasywny monitor sieciowy
```

```
## Wymagania
```

* System Ubuntu z uprawnieniami `sudo`
* Zainstalowane pakiety: `suricata`, `curl`

Instalacja

sudo apt update && sudo apt install suricata -y

Konfiguracja

1. W `/etc/suricata/suricata.yaml` dodano wpis `- local.rules` w sekcji `rule-files:` oraz ustawiono `interface: enp0s3` w sekcji `af-packet`.
2. Dodano regułę testową ICMP do `/etc/suricata/rules/local.rules`:
alert icmp any any -> any any (msg:"TEST ICMP DETECTED"; sid:1000002; rev:1;)

Test działania

1. Uruchomienie usługi:
sudo systemctl restart suricata
2. Weryfikacja ruchu w drugim okienku:
ping -c 2 8.8.8.8
3. Wykrycie alertu w logach na żywo.

Gdzie są logi i alerty

* Plik alertów tekstowych: `/var/log/suricata/fast.log`
* Plik zdarzeń JSON: `/var/log/suricata/eve.json`

Jak zatrzymać albo wycofać zmiany

* Zatrzymanie: `sudo systemctl stop suricata`
* Usunięcie: `sudo apt remove --purge suricata -y`

Wnioski security

Suricata pasywnie analizuje pakiety na karcie `enp0s3`. Błędne reguły nie paraliżują sieci, jednak IDS jedynie informuje o ataku – wymaga reakcji administratora.
EOF

Zadanie 3 Architektura bezpieczeństwa dla niewielkiej firmy farmaceutycznej

(45 pracowników (20 biuro/sprzedaż, 10 laboratorium kontroli jakości, 12 produkcja, 3 IT/Security))

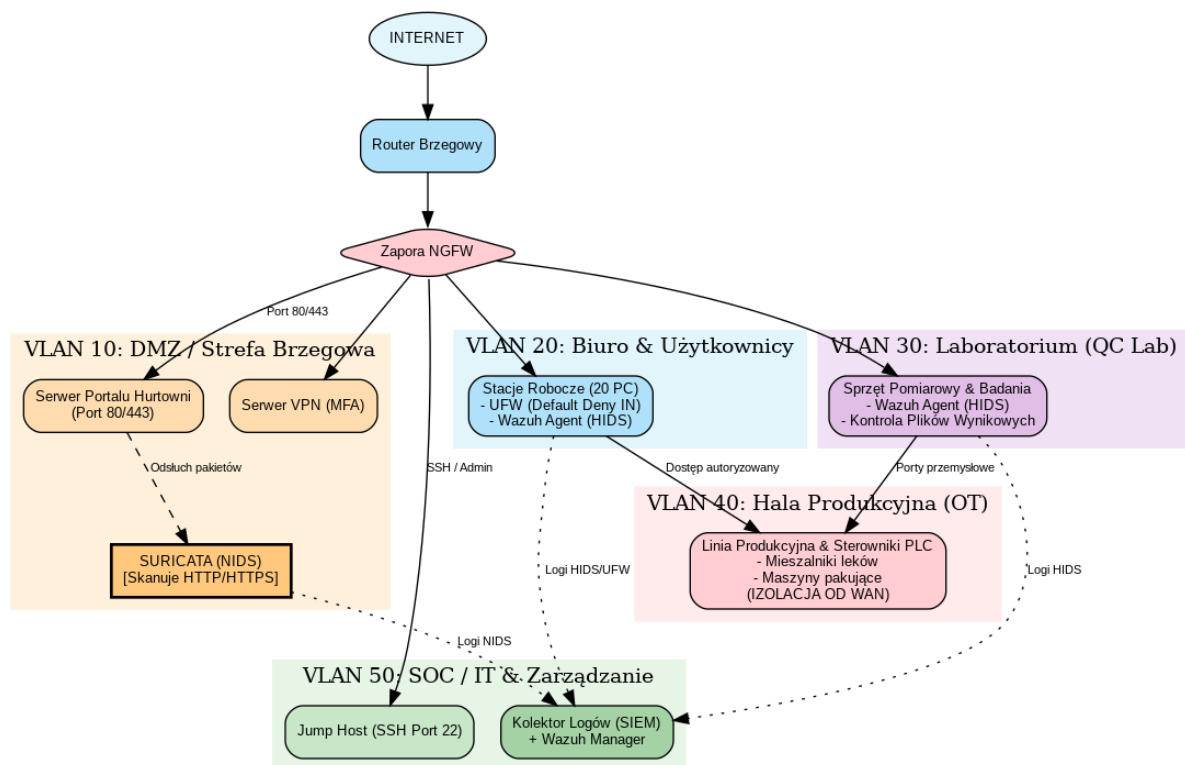
1. Segmentacja sieci (VLAN) i punkty kontroli:

- VLAN 10 – DMZ (Strefa Brzegowa):
 - *Zasoby*: Serwer Portalu Klienta/Hurtowni (składanie zamówień), Serwer VPN dla pracowników zdalnych.
 - *Ochrona*: Suricata (NIDS) ustawiona pasywnie na styku z Internetem (analiza zapytań HTTP/HTTPS pod kątem ataków webowych i skanowania sieci).
- VLAN 20 – Biuro i Administracja (Stacje Użytkowników):
 - *Zasoby*: 20 komputerów biurowych (księgowość, HR, handel).

- *Ochrona*: UFW (Host Firewall) na każdym hoście z regułą **default deny incoming** (przepuszcza tylko niezbędne połączenia). Zintegrowany agent Wazuh (HIDS) monitorujący próby podłączenia pendrive'ów i logowania.
- VLAN 30 – Laboratorium Kontroli Jakości (QC Lab):
 - *Zasoby*: Komputery połączone ze sprzętem pomiarowym (np. spektrometry, chromatografy).
 - *Ochrona*: Dostęp do serwera plików wyłącznie do odczytu. Wazuh (HIDS) śledzi integralność plików z wynikami badań próbek (wymóg integralności danych medycznych).
- VLAN 40 – Hala Produkcyjna (Strefa OT / Produkcja Lębów):
 - *Zasoby*: Sterowniki PLC, mieszalniki, linie do pakowania tabletek.
 - *Ochrona*: Całkowita izolacja od Internetu. Ruch przychodzący z biura i laboratorium zablokowany na poziomie routera/zapory (z wyjątkiem autoryzowanych portów protokołów przemysłowych).
- VLAN 50 – SOC / IT i Administracja:
 - *Zasoby*: Jump Host (Bastion SSH/RDP), Serwer Logów (Wazuh Manager / SIEM).
 - *Ochrona*: Centralne zbieranie zdarzeń. Dostęp do zarządzania siecią wyłącznie z użyciem kluczy SSH/MFA po porcie 22.

2. Zastosowanie mechanizmów z zajęć (Przepływ ruchu):

- UFW (Zapora na hoście): Wdrożona na serwerze zamówień w DMZ (otwarte tylko porty **80/tcp**, **443/tcp** oraz **22/tcp** tylko dla IP administratora). Ruch inicjowany z strefy DMZ w kierunku Laboratorium (VLAN 30) lub Produkcji (VLAN 40) jest w 100% odrzucany.
- Suricata (IDS): Analizuje pakiety wchodzące z Internetu do DMZ. Wykrywa np. wywołania powłoki (Web Shell) lub skanowanie portów, odnotowując zdarzenia w **/var/log/suricata/fast.log**.
- Korelacja logów: Zdarzenia z UFW, logi systemowe z komputerów laboratoryjnych oraz alerty z Suricaty spływają do centralnej strefy SOC (VLAN 50), umożliwiając szybkie wykrycie np. próby zainfekowania komputera w laboratorium z poziomu sieci biurowej.



Podsumowanie punktów inspekcji i mechanizmów na diagramie:

- **Styk z Internetem / DMZ (VLAN 10):** Zapora brzegowa przekierowuje ruch 80/443. **Suricata (NIDS)** jest podpięta w trybie pasywnym i skanuje cały ruch wchodzący do serwera hurtowni leków.
- **Segmentacja stref wewnętrznych:** Zapora NGFW uniemożliwia dowolny ruch z strefy DMZ do sieci wewnętrznej.
- **Laboratorium i Biuro (VLAN 20 & 30):** Każda stacja robocza chroniona jest zapora **UFW (default deny incoming)** oraz posiada agenta **Wazuh (HIDS)** śledzącego integralność plików tekstowych z wynikami badań próbek leków.
- **Strefa Produkcyjna (VLAN 40):** Izolowana od świata zewnętrznego. Brak bezpośredniej trasowalności do Internetu.
- **SOC / IT (VLAN 50):** Centralny punkt zbierania alertów – logi z UFW, zdarzenia z Suricaty oraz alerty HIDS z Wazuha spływają do jednego serwera logów. Zdalny dostęp administracyjny odbywa się wyłącznie przez Jump Host po SSH.

Zadanie 4 (Odpowiedzi na pytania):

IDS vs IPS: IDS tylko ostrzega, więc błąd w regule wygeneruje fałszywy alarm. IPS blokuje pakiety, więc błąd może odciąć ruch w całej firmie.

Błędny DROP w IPS: Zablokuje poprawny ruch klientów lub odetnie administratorów od serwera.

NIDS vs HIDS: NIDS analizuje ruch sieciowy między urządzeniami. HIDS monitoruje zdarzenia wewnątrz konkretnego systemu (pliki, logi, procesy).

Alert bez reakcji: Nie zatrzymuje ataku — jest jedynie bezużyteczną informacją po fakcie.

Korelacja logów: Logi UFW (ufw.log), autoryzacji (auth.log), serwera WWW (access.log) oraz logi systemowe (journalctl).